

Enterprise Information Security & Access Policy

SOC-2 Type II Trust Services Criteria & ISO/IEC 27001:2022 Alignment

1. Executive Summary & Organizational Scope

This policy governs all information assets, software environments, and physical devices owned, leased, or operated by ComplyAI Corporation. Compliance with this policy is mandatory for all full-time employees, contractors, vendors, and third-party affiliates with access to internal network infrastructure.

2. Governance Roles & Accountability

- Chief Information Security Officer (CISO): Responsible for annual policy reviews, external SOC-2 Type II audit management, and cyber risk governance.
- Security Operations Center (SOC): Maintains 24/7 continuous log monitoring, SIEM alerting, and threat detection.
- Department Heads: Ensure 100% of staff complete mandatory quarterly security awareness training within 14 calendar days of assignment.

Classification Level	Description	Protection Requirement
Restricted	Customer PII, cryptographic keys, credentials	AES-256 at rest, strict RBAC, MFA
Confidential	Financial statements, vendor contracts, source code	Role-based authorization, encrypted storage
Internal	Org charts, internal wikis, project timelines	SSO login required, company-internal only
Public	Marketing assets, public documentation	No restriction, public read-only

3. Access Control & Password Management Standards

Authentication into ComplyAI production environments, developer tools, and customer databases must satisfy the following cryptographic standards without exception:

1. Password Length & Complexity: Passwords must contain a minimum of 14 characters, combining uppercase letters, lowercase letters, numbers, and at least one non-alphanumeric symbol (!@#\$%^&*).
2. Mandatory Password Expiration: Passwords must be rotated every 90 days. Systems must prohibit the reuse of the previous 12 historical passwords.
3. Multi-Factor Authentication (MFA): MFA is mandatory across all accounts. Production cloud environments (AWS/GCP) strictly require FIDO2 / WebAuthn hardware security keys (e.g. YubiKey). SMS-based 2FA is prohibited.
4. Account Lockout Threshold: Accounts are automatically locked after 5 consecutive failed login attempts. Unlocking requires IT Helpdesk identity verification.
5. Session Timeouts: Corporate workstation screens and active browser sessions must automatically lock after 15 minutes of user inactivity.

4. Cryptographic Encryption Architecture

- Data at Rest: All production databases (PostgreSQL, SQLite), cloud storage buckets (AWS S3, GCS), and backup volumes must enforce AES-256-GCM encryption with automated KMS key rotation every 365 days.
- Data in Transit: All external API communication and internal microservice mesh traffic must enforce TLS 1.3 protocol. TLS 1.0, 1.1, and unencrypted HTTP traffic are permanently rejected.

5. Incident Response Protocols & Severity SLAs

Security incidents must be escalated according to the following strict Service Level Agreements (SLAs):

Severity Level	Example Event	Acknowledge SLA	Resolution SLA
P1 - Critical	Ransomware, active data breach, DB exfiltration	15 minutes	4 hours
P2 - High	Compromised employee account, DoS attack	1 hour	12 hours
P3 - Medium	Policy violation, unauthorized USB device plugged	4 hours	48 hours
P4 - Low	Spam email campaign, minor vulnerability patch	24 hours	5 business days

6. Statutory Data Retention & Disposal Requirements

- Financial, Billing & Tax Records: Retained for a statutory period of 7 years in write-once-read-many (WORM) storage.
- Security Audit Logs, Firewall Logs & Access Records: Retained for 3 years to support forensic investigations.
- Customer Operational Data: Terminated customer records must be cryptographically sanitized or destroyed within 30 days of contract expiration.